

The Regulatory Cheatsheet

Five frameworks applied to AI in community banking. The current regulatory landscape on one card — and the staff-level implications of each.

What examiners apply to AI today

No single law governs AI in banking. Existing supervisory, consumer-protection, third-party-risk, and BSA/AML frameworks do the work today. Per GAO-25-107197 (May 2025), federal regulators are overseeing AI through existing authorities while monitoring how financial institutions use AI.

TABLE REFLOWED FOR LARGE PRINT

SR 26-2 / revised MRM guidance

REGULATOR

Federal Reserve / OCC / FDIC

HOW IT APPLIES TO AI

Supersedes legacy SR 11-7-era model-risk framing. Applies a risk-based model-risk approach tied to model purpose, exposure, validation, monitoring, governance, controls, and vendor/third-party products. Most relevant to banking organizations over \$30B in assets, but useful as a model-risk reference point for smaller institutions with material models.

STAFF-LEVEL IMPACT

Do not label every AI workflow as a model. First determine whether the tool is a model, vendor service, workflow aid, or policy process. If it influences risk, credit, fraud, BSA/AML, pricing, or other material decisions, document purpose, limits, monitoring, human review, and escalation.

Interagency TPRM

REGULATOR

OCC / FDIC / NCUA / CFPB

HOW IT APPLIES TO AI

Every AI vendor tool — including Microsoft Copilot, ChatGPT Enterprise, and AI-enabled core features — requires a third-party risk assessment before deployment.

STAFF-LEVEL IMPACT

Do not activate new AI vendor tools without IT and compliance completing TPRM review. Free-tier and personal accounts are not exempt from institutional policy.

ECOA / Reg B

REGULATOR

CFPB

HOW IT APPLIES TO AI

AI-driven lending and credit models must provide specific, human-readable adverse-action reasons. Black-box "score too low" outputs do not satisfy ECOA requirements.

STAFF-LEVEL IMPACT

If AI touches any lending or credit decision, adverse-action explanations must be traceable, specific, and understandable to the customer — not just the model.

BSA / AML

REGULATOR

FinCEN

HOW IT APPLIES TO AI

AI transaction-monitoring systems must meet the same documentation and auditability standards as manual SAR processes. AI alerts do not reduce examiner scrutiny.

STAFF-LEVEL IMPACT

AI-generated SAR recommendations require human review and approval before filing. Regulatory accountability remains with staff — the AI does not carry it.

AIEOG AI Lexicon

REGULATOR

US Treasury / FBIIC / FSSCC

HOW IT APPLIES TO AI

Published February 2026.
Establishes shared regulatory definitions for hallucination, AI governance, AI use case inventory, HITL, third-party AI risk, and explainability.

STAFF-LEVEL IMPACT

Align your institution's AI policy language with AIEOG Lexicon definitions. Inconsistent terminology in policy documents creates examination risk.

Examination context. SR 26-2 / OCC Bulletin 2026-13 / FDIC FIL-15-2026 is the current interagency model-risk reference, not old SR 11-7-only framing. It does not replace ECOA / Reg B, Interagency TPRM, GLBA / Reg P, BSA/AML, or institution-specific compliance review. For AI, the practical question is which existing framework applies to the use case.

Six terms every banker needs to know

Source: US Treasury / FBIIC / FSSCC — February 2026. Regulators will use this vocabulary in AI-related examination findings. Align your institution's AI policy language with these definitions to reduce examination risk.

Hallucination

An AI output that is factually incorrect, fabricated, or misleading, presented with apparent confidence.

Distinct from ordinary model error — specifically refers to outputs lacking grounding in source data. Regulators treat hallucination risk as a governance and disclosure concern.

HITL (Human-in-the-Loop)

A design pattern in which a human reviews or approves AI-generated outputs before they are acted upon.

Required for any AI system that makes or influences material decisions affecting customers. HITL cannot be delegated away by policy — it must be operationally enforced.

AI Governance

The policies, processes, roles, and organizational structures that define how an institution develops,

Third-Party AI Risk

Risks arising from AI systems operated by vendors or service providers. Interagency

acquires, deploys, monitors, and retires AI systems. Applies to the institutional AI program as a whole, not to individual models in isolation.

TPRM guidance requires the same risk-assessment rigor for AI-enabled vendor tools as for any other critical third party — including cloud-hosted AI APIs.

AI Use Case Inventory

A structured, maintained record of all AI systems and tools in active use at an institution, including purpose, data inputs, outputs, and applicable risk controls. Treated as a baseline AI governance requirement by examiners and regulators.

Explainability

The capacity of an AI system to provide human-understandable reasons for its outputs. For model use, revised model-risk guidance still expects conceptual soundness, validation, monitoring, and governance. For customer-impacting decisions, ECOA / Reg B and related review expectations require clear, traceable reasons.

Examination risk note. Regulators will use AIEOG Lexicon definitions in AI-related examination findings. If your institution's AI policy uses different terminology for hallucination, HITL, or explainability, examiners may interpret that as a governance gap. Review your AI policy language against this vocabulary before your next examination cycle.

Source basis: Federal Reserve SR 26-2 and attachment, "Supervisory Guidance on Model Risk Management" (April 17, 2026); OCC Bulletin 2026-13; FDIC FIL-15-2026; GAO-25-107197 (May 2025); Interagency Third-Party Risk Management Guidance; ECOA / Regulation B (CFPB); FinCEN BSA/AML guidance; AIEOG AI Lexicon (US Treasury / FBIIC / FSSCC, February 2026); AiBI Foundations curriculum, Module 1.

This cheat sheet is a starter artifact, not legal advice or an examiner-approved regulatory interpretation. Adapt before adoption and confirm final policy language with compliance, legal, and risk leadership.